

用户管理系统

安全漏洞修复报告

三处安全漏洞分析与修复方案

安全

目 录

一、项目概述

二、初始源代码（三处漏洞全部存在）

三、三处漏洞的代码修改对比

漏洞一：密码明文存储 明文比对

漏洞二：弱

漏洞三：注释泄露管理员账号

四、每处漏洞修复后的完整源代码

修复漏洞一之后

修复漏洞二之后

修复漏洞三之后

五、最终完整源代码（全部修复）

六、修改行号对照总表

一、项目概述

本项目是一个简易用户信息管理平台的登录功能，使用 框架构建。项目包含个文件：（主应用）、（基础模板）、（登录页）、（首页）、（样式文件）。

初始版本故意留有 个安全漏洞用于教学演示，以下逐一展示并修复。

漏洞列表：

漏洞一：密码以明文形式存储在字典中，使用 直接比较，登录后密码原文暴露在页面上

漏洞二： 硬编码为 ，可被 解签伪造

漏洞三： 中 注释直接泄露管理员账号密码

二、初始源代码（三处漏洞全部存在）

（漏洞版）

```
from flask import Flask, render_template, request, redirect, session

app = Flask(__name__)
app.secret_key = "dev-key-2025"

#
USERS = {
    "admin": {
        "username": "admin",
        "password": "admin123",
        "role": "admin",
        "email": "admin@example.com",
        "phone": "13800138000",
        "balance": 99999
    },
    "alice": {
        "username": "alice",
        "password": "alice2025",
        "role": "user",
        "email": "alice@example.com",
        "phone": "13900139001",
        "balance": 100
    }
}

@app.route("/")
def index():
    username = session.get("username")
    user = None
    if username and username in USERS:
        user = USERS[username]
    return render_template("index.html", user=user)

@app.route("/login", methods=["GET", "POST"])
def login():
    error = None
    if request.method == "POST":
        username = request.form.get("username", "")
        password = request.form.get("password", "")
        #
        if username in USERS and USERS[username]["password"] == password:
            session["username"] = username
            user = USERS[username]
            return render_template("index.html", user=user)
        else:
```

```
        error = ""
    return render_template("login.html", error=error)

@app.route("/logout")
def logout():
    session.clear()
    return redirect("/")

if __name__ == "__main__":
    app.run(debug=True, host="0.0.0.0", port=5000)
```

（漏洞版）

```
{% extends "base.html" %}
{% block content %}
<div class="card">
    {% if user %}
        <h2>{{ user.username }}</h2>
        <h3></h3>
        <ul class="user-info">
            <li><strong></strong>{{ user.username }}</li>
            <li><strong></strong>{{ user.password }}</li>
            <li><strong></strong>{{ user.email }}</li>
            <li><strong></strong>{{ user.phone }}</li>
            <li><strong></strong>{{ user.role }}</li>
            <li><strong></strong>{{ user.balance }}</li>
        </ul>
        <a href="/logout" class="btn btn-logout"></a>
    {% else %}
        <h2></h2>
        <p></p>
        <a href="/login" class="btn"></a>
    {% endif %}
</div>
{% endblock %}
```

（漏洞版）

```
<!-- - : admin : admin123 -->
{% extends "base.html" %}
{% block content %}
<div class="card">
    <h2></h2>
    ...
</div>
{% endblock %}
```

（未改动）

```
<!DOCTYPE html>
<html lang="zh-CN">
```

```
<head>
  <meta charset="UTF-8">
  <title></title>
  <link rel="stylesheet" href="/static/css/style.css">
</head>
<body>
  <nav class="navbar">
    <div class="nav-left">
      <span class="brand"></span>
    </div>
    <div class="nav-right">
      {% if session.get('username') %}
        <span class="nav-welcome">{{ session['username'] }}</span>
        <a href="/logout" class="nav-link"></a>
      {% else %}
        <a href="/login" class="nav-link"></a>
      {% endif %}
    </div>
  </nav>
  <main class="container">
    {% block content %}{% endblock %}
  </main>
</body>
</html>
```

三、三处漏洞的代码修改对比

漏洞一：密码明文存储 明文比对

涉及文件：

问题说明：字典中密码以明文存储（），登录时用直接比较字符串，登录后首页直接输出 暴露密码原文。

修改一：新增安全库导入

修改前	修改后
from flask import Flask, render_template, request, redirect	from flask import Flask, render_template, request, redirect, session from werkzeug.security import generate_password_hash, check_password_hash

修改二：字典密码哈希化

修改前	修改后
"password": "admin123", "password": "alice2025",	"password": generate_password_hash("admin123"), "password": generate_password_hash("alice2025"),

修改三：登录比对方式

修改前	修改后
# if username in USERS and USERS[username]["password"] == password:	# == if username in USERS and check_password_hash(USERS[username]["password"], password):

修改四：页面密码展示

修改前	修改后
{{ user.password }}	*****

漏洞二：弱 （ 伪造风险 ）

涉及文件：

问题说明： 硬编码为 ，这是一个公开的弱密钥。攻击者可使用 工具解签 ，篡改其中 字段后重新签名，从而伪造任意用户身份登录系统。

修改一： 新增 模块导入

修改前	修改后
from flask import Flask, render_template, request, redirect,	from flask import Flask, render_template, request, redirect, s from werkzeug.security import generate_password_hash, check_pa import os

修改二： 改为随机生成

修改前	修改后
app.secret_key = "dev-key-2025"	app.secret_key = os.urandom(24).hex() # session

漏洞三：注释泄露管理员账号

涉及文件：

问题说明： 第 行
注释中直接写明了默认管理员的用户名和密码，任何用户通过查看页面源代码（ 或右键查看源代码 ）即可获取登录凭证。

注释内容修改

修改前	修改后
<!-- - : admin : admin123 -->	<!-- - -->

四、每处漏洞修复后的完整源代码

修复漏洞一之后（漏洞二、三仍存在）

说明：此处仅修复了漏洞一（密码哈希化），中 仍为（漏洞二），仍包含泄露账号的注释（漏洞三）。

```
from flask import Flask, render_template, request, redirect, session
from werkzeug.security import generate_password_hash, check_password_hash # ←

app = Flask(__name__)
app.secret_key = "dev-key-2025" # ←

#
USERS = {
    "admin": {
        "username": "admin",
        "password": generate_password_hash("admin123"), # ←
        "role": "admin",
        "email": "admin@example.com",
        "phone": "13800138000",
        "balance": 99999
    },
    "alice": {
        "username": "alice",
        "password": generate_password_hash("alice2025"), # ←
        ...
    }
}
...
# ==
if username in USERS and check_password_hash(USERS[username]["password"], password):
```

修复漏洞二之后（漏洞三仍存在）

说明：漏洞一和漏洞二已修复。中密码已哈希、已随机生成，但仍包含泄露账号的注释。

```
from flask import Flask, render_template, request, redirect, session
from werkzeug.security import generate_password_hash, check_password_hash
import os # ←

app = Flask(__name__)
app.secret_key = os.urandom(24).hex() # session # ←

#
USERS = {
    "admin": {
        "username": "admin",
```

```
        "password": generate_password_hash("admin123"),
        ...
    },
    "alice": {
        "username": "alice",
        "password": generate_password_hash("alice2025"),
        ...
    }
}
...
# login.html
<!-- - : admin : admin123 --> # ←
```

修复漏洞三之后（全部修复完成）

说明：注释中的敏感信息已删除，三处漏洞全部修复完毕。

```
<!-- - --> # ←
{% extends "base.html" %}
{% block content %}
<div class="card">
    ...
</div>
{% endblock %}
```

五、最终完整源代码（全部修复）

（最终版）

```
from flask import Flask, render_template, request, redirect, session
from werkzeug.security import generate_password_hash, check_password_hash
import os

app = Flask(__name__)
app.secret_key = os.urandom(24).hex() #

#
USERS = {
    "admin": {
        "username": "admin",
        "password": generate_password_hash("admin123"),
        "role": "admin",
        "email": "admin@example.com",
        "phone": "13800138000",
        "balance": 99999
    },
    "alice": {
        "username": "alice",
        "password": generate_password_hash("alice2025"),
        "role": "user",
        "email": "alice@example.com",
        "phone": "13900139001",
        "balance": 100
    }
}

@app.route("/")
def index():
    username = session.get("username")
    user = None
    if username and username in USERS:
        user = USERS[username]
    return render_template("index.html", user=user)

@app.route("/login", methods=["GET", "POST"])
def login():
    error = None
    if request.method == "POST":
        username = request.form.get("username", "")
        password = request.form.get("password", "")
        if username in USERS and check_password_hash(USERS[username]["password"], password):
            session["username"] = username
```

```

        user = USERS[username]
        return render_template("index.html", user=user)
    else:
        error = ""
    return render_template("login.html", error=error)

@app.route("/logout")
def logout():
    session.clear()
    return redirect("/")

if __name__ == "__main__":
    app.run(debug=True, host="0.0.0.0", port=5000)

```

（最终版）

```

{% extends "base.html" %}
{% block content %}
<div class="card">
    {% if user %}
        <h2>{{ user.username }}</h2>
        <h3></h3>
        <ul class="user-info">
            <li><strong></strong>{{ user.username }}</li>
            <li><strong></strong>*****</li>
            <li><strong></strong>{{ user.email }}</li>
            <li><strong></strong>{{ user.phone }}</li>
            <li><strong></strong>{{ user.role }}</li>
            <li><strong></strong>{{ user.balance }}</li>
        </ul>
        <a href="/logout" class="btn btn-logout"></a>
    {% else %}
        <h2></h2>
        <p></p>
        <a href="/login" class="btn"></a>
    {% endif %}
</div>
{% endblock %}

```

（最终版）

```

<!-- - ->
{% extends "base.html" %}
{% block content %}
<div class="card">
    <h2></h2>
    <form method="post" action="/login" class="login-form">
        <div class="form-group">
            <label for="username"></label>

```

```
        <input type="text" id="username" name="username" placeholder="" required>
    </div>
    <div class="form-group">
        <label for="password"></label>
        <input type="password" id="password" name="password" placeholder="" required>
    </div>
    {% if error %}
        <p class="error-msg">{{ error }}</p>
    {% endif %}
    <button type="submit" class="btn"></button>
</form>
</div>
{% endblock %}
```

（最终版，未改动）

```
<!DOCTYPE html>
<html lang="zh-CN">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title></title>
    <link rel="stylesheet" href="/static/css/style.css">
</head>
<body>
    <nav class="navbar">
        <div class="nav-left">
            <span class="brand"></span>
        </div>
        <div class="nav-right">
            {% if session.get('username') %}
                <span class="nav-welcome">{{ session['username'] }}</span>
                <a href="/logout" class="nav-link"></a>
            {% else %}
                <a href="/login" class="nav-link"></a>
            {% endif %}
        </div>
    </nav>
    <main class="container">
        {% block content %}{% endblock %}
    </main>
</body>
</html>
```

（最终版，未改动）

```
/* reset */
* { margin: 0; padding: 0; box-sizing: border-box; }
body { font-family: ...; background-color: #f5f7fa; ... }

/* - */
```

```
.navbar { background: linear-gradient(135deg, #667eea, #764ba2); ... }

/* - */
.card { background: #fff; border-radius: 12px; box-shadow: 0 4px 20px ...; }

/* - */
.form-group input { border: 1px solid #ddd; padding: 10px 14px; ... }

/* - */
.btn { background: linear-gradient(135deg, #667eea, #764ba2); ... }
```

六、修改行号对照总表

漏洞	文件	行号	修改前	修改后	风险等级
漏洞一		第行	无安全导入		高
漏洞一		第行	明文		高
漏洞一		第行	直接比		高
漏洞一		第行		掩码	中
漏洞二		第行	无 导入	加	高
漏洞二		第行			高
漏洞三		第行		请联系管理员	高

修复后验证结果

- 登录成功，首页密码显示为【已加密保护】
- 错误密码 登录失败，提示用户名或密码错误！
- 未登录用户看到请先登录提示
- 密钥每次启动随机生成，无法伪造
- 查看 页面源代码，无法获取管理员账号信息